

Compliance-Driven Penetration Test

Pre-Engagement and Scoping

Scenario A – PCI-DSS | Client: NorthPeak Outfitters Inc.

Prepared by: Marco Hélie

Engagement context. NorthPeak Outfitters Inc. is a medium-sized online retailer selling outdoor gear across Canada. It processes roughly 40,000 card-not-present transactions per month (about 480,000 per year) through a public e-commerce website. Checkout uses a JavaScript / direct-post integration in which NorthPeak's own page renders and controls the payment form while card data is transmitted directly to the payment processor. Because the merchant's website can influence the security of the payment page, NorthPeak validates under SAQ A-EP, whose control set includes the Requirement 11.4 penetration test. Based on its e-commerce volume, NorthPeak self-assesses as a PCI-DSS Level 3 merchant and must produce evidence of an annual penetration test to renew its compliance for the coming year. This document covers the pre-engagement and scoping phase for that test.

Step 2 — Compliance Requirement Research

What is the purpose of the compliance requirement?

The Payment Card Industry Data Security Standard (PCI-DSS) is a set of security controls created by the PCI Security Standards Council and enforced through the major card brands. Its purpose is to protect cardholder data wherever it is stored, processed, or transmitted, and to reduce the fraud and breach risk that results from weak handling of payment information. Any organization that accepts, processes, or stores credit card data is contractually required to comply. The current standard is PCI-DSS v4.0.1, and all future-dated v4.x requirements became mandatory on March 31, 2025, so a compliant program can no longer rely on the older v3.2.1 approach.

Why would the organization need a penetration test?

Penetration testing is an explicit, named obligation under PCI-DSS Requirement 11.4 (previously 11.3 under v3.2.1), and it is part of the SAQ A-EP control set that applies to NorthPeak. Requirement 11.4 mandates internal and external penetration testing at least every 12 months and after any significant change to the environment, using a documented methodology based on an industry-accepted approach such as NIST SP 800-115, and covering both the network and application layers. Exploitable findings must be remediated and then retested to verify the fix. For NorthPeak, the test is required both to satisfy this control for its annual self-assessment and to give the business real assurance — beyond an automated scan — that its e-commerce environment can withstand a realistic attack before renewal.

What assets or data must be protected?

The data to protect is cardholder data (CHD) — the Primary Account Number (PAN), and where present the cardholder name and expiry date — together with sensitive authentication data such as CVV, which is captured as the customer types it into the payment form. Even though the PAN is transmitted directly to the processor under SAQ A-EP, the merchant's own environment can affect its security and is therefore in scope: the e-commerce web application and payment page, the web and application servers, the scripts running on the checkout page, administrative interfaces, and any connected system that could provide a path to influence the payment page. Protecting these assets means safeguarding the confidentiality, integrity, and availability of payment data throughout the checkout process.

Step 3 — Penetration Test Scope

The following defines what is authorized for testing in this engagement and what is explicitly excluded. Scope is deliberately anchored to NorthPeak's e-commerce environment and the systems that can affect the security of the payment page.

In Scope / Out of Scope

In Scope	Out of Scope
Public e-commerce website and checkout / payment page (www.northpeak-outfitters.ca)	Third-party payment processor / gateway internals (Stripe / Moneris back end)
Customer web application: authentication, cart, checkout, and account APIs	Cloud provider infrastructure below the customer boundary (AWS physical/hypervisor)
E-commerce web / application servers and supporting order-management systems	Corporate HR, payroll, and email systems outside the in-scope environment
External network perimeter: public IP range, firewall, and exposed services	Physical security testing and social-engineering of staff
Payment-page scripts and their integrity/tamper-detection controls	Denial-of-service (DoS/DDoS) and volumetric load testing
Internal segment hosting in-scope systems and the segmentation controls	Production data destruction or any test that alters real customer orders
Administrative and staff login portals connected to in-scope systems	Employee personal devices and out-of-scope branch office networks

Note: Third-party services (e.g., the payment processor and cloud provider) are out of scope for active testing because they are governed by their own PCI-DSS compliance and Attestations of Compliance. Any restriction listed above may only be lifted through written change approval from the client.

Business Objectives

- **Satisfy PCI-DSS Requirement 11.4.** Obtain a documented, methodology-based penetration test and report to support the annual SAQ A-EP self-assessment.
- **Protect cardholder data.** Identify and validate exploitable weaknesses that could expose or intercept payment data, then remediate and retest before they can be abused.
- **Confirm segmentation and reduce scope.** Verify that in-scope systems are properly isolated from the rest of the network, protecting customer trust and limiting the systems subject to future assessments.

Step 4 — Pre-Engagement Questionnaire

The following questions would be sent to NorthPeak before testing begins to confirm scope, size the effort accurately, and avoid disrupting the business.

Question	Why it matters
How many live IP addresses, hosts, and public endpoints are in scope?	Defines the size of the attack surface so the engagement can be scoped, priced, and time-boxed accurately.
How many web applications and APIs will be tested, and how complex are they (authenticated flows, roles, checkout)?	Application testing effort scales with functionality; checkout and account APIs are the highest-risk paths related to payment data.
Which cloud services and hosting providers are used, and what is the customer-vs-provider responsibility boundary?	Clarifies what we are contractually allowed to test versus what belongs to the provider's own PCI compliance.
What is the preferred testing window (dates, hours, time zone) and are off-hours required?	Protects production traffic and revenue by scheduling intrusive tests when customer impact is lowest.
Which SAQ type and specific PCI-DSS requirements must this test satisfy?	Ensures the methodology and report content map to SAQ A-EP and Requirement 11.4 and produce evidence the assessor will accept.
What security controls are in place (WAF, IDS/IPS, EDR, rate limiting) and should any be tuned or bypassed for testing?	Prevents testers from being blocked mid-engagement and clarifies whether we test the control or the underlying system.
Is network segmentation used to isolate in-scope systems, and can we obtain the segmentation design?	Segmentation testing is required under Req 11.4.5; the design tells us which paths into the in-scope environment to validate.
Will test/staging environments be provided, or must testing occur against production?	Determines risk of business disruption and whether destructive checks are permitted safely.
Who are the technical and emergency points of contact, and what is the escalation path?	Enables rapid communication if a critical vulnerability or an outage is discovered during testing.
Are there any fragile systems, blackout periods, or legal/regulatory constraints we must respect?	Avoids damaging sensitive assets and keeps the engagement within legal and contractual limits.

Step 5 — Recommended Testing Strategy

Test type: Gray-Box

I recommend a gray-box approach. In a gray-box test the tester receives limited information and low-privileged credentials (for example, a standard customer account and a staff/admin account) rather than either nothing (black-box) or full source code and architecture (white-box). This best fits a PCI engagement because it realistically simulates both an external anonymous attacker and a legitimate but malicious or compromised user, which is exactly how cardholder data is most often exposed. Pure black-box testing wastes budget on reconnaissance and risks leaving authenticated checkout and account flows under-tested; full white-box is thorough but less representative of a real attack and unnecessary for confirming the exploitability that Requirement 11.4 emphasizes. Gray-box delivers the deepest coverage of the in-scope environment for the available time.

Notification: Announced

I recommend an announced test. NorthPeak's technical and emergency contacts should know the testing window in advance. The goal of a PCI penetration test is to find and validate exploitable weaknesses in the environment, not to measure the SOC's detection and response (that would call for an unannounced red-team exercise). Announcing the test lets staff distinguish testing traffic from a real attack, keeps monitoring controls in place, allows rapid escalation if a critical issue or outage occurs, and protects the business from unnecessary incident response costs — all while still producing the compliance evidence required.

Step 6 — Key Rules of Engagement

Authorized Testing Times

Testing is authorized only during the agreed window of Monday–Thursday, 20:00–02:00 Eastern Time, over a two-week period, to minimize impact on peak customer traffic. Any testing outside this window requires prior written approval from the client's designated contact.

Approved Testing Activities

- External and internal network penetration testing of in-scope systems
- Web application and API testing (OWASP-style, including authenticated flows)
- Vulnerability identification, manual exploitation, and controlled privilege escalation
- Segmentation validation between in-scope systems and other network zones
- Non-destructive proof-of-concept only — no exfiltration of real cardholder data

Emergency Contacts

- **Client technical lead:** J. Tremblay, IT Manager — +1 (514) 555-0142, available during all test windows.
- **Client emergency / after-hours:** NorthPeak on-call operations — +1 (514) 555-0199.
- **Test team lead:** M.-O. Hélie — reachable via secure channel throughout the engagement.

Stop-Testing Conditions

Testing will be paused or halted immediately if any of the following occur: a critical vulnerability exposing live cardholder data is discovered (report immediately, do not exploit further); a system outage or service degradation is caused by testing; evidence of a pre-existing, active compromise is found; or the client issues a stop request. Testing resumes only after both parties agree in writing.

Reporting Requirements

Critical findings will be reported to the client's technical lead within 24 hours of discovery. A full written report will be delivered within five business days of the engagement's end, containing an executive summary, the documented methodology, findings with CVSS severity ratings, evidence, and remediation guidance mapped to PCI-DSS Requirement 11.4. A retest of remediated critical and high findings is included to confirm fixes, as required for compliance.